告警研判智能体系统研究

范　敏[1]　张林波[2]　李　展[3]　燕敬博[2]　陈　亘[1]　刘丽丽[4]　董逸天[2]
[1](北京启明星辰信息安全技术有限公司　北京　100000)
[2](国家计算机网络应急技术处理协调中心　北京　100000)
[3](西南交通大学　成都　610000)
[4](中国人民解放军 61660 部队　北京　100000)
(fan_min2@venusgroup.com.cn)

摘　要　为准确分析海量网络威胁入侵告警，快速定位高优先级且亟需处理的日志，减轻安全人员告警疲劳并提高威胁分析效率，设计并提出一种告警研判智能体系统 RIGTE-Agent-CV.一方面，该系统利用 ReAct 框架的智能体技术融合专家研判经验与安全工具响应，在不需要微调大语言模型的前提下有效减少了开源模型的研判幻觉.另一方面，该系统基于代码提示构建了 RIGTE 提示词框架，有效提升了研判智能体的指令遵循和条件推理能力.同时，结合自我一致性的多数投票机制，进一步提高了研判的准确率.公共数据集与自有数据集实验结果表明，融合代码提示与自我一致性方法可提高模型推理能力并减少随机性，验证了所提系统的有效性和可行性.

关键词　告警研判；大语言模型；智能体

中图法分类号　TP393.08

1　研究背景

在数字化转型加速推进的背景下，网络攻击呈现出规模化、复杂化与隐蔽化的特征.为防御网络攻击，企业常购买 IDS，WAF，EDR 等安全产品.此类产品主要依赖检测规则生成告警，易产生大量误报，导致企业每日需处理海量安全告警.基于人工的告警分析存在研判效率低下、时效性差、告警疲劳等不足.因此，自动化告警研判尤为重要.当前，自动化告警研判有以下 3 种主流方法：

1）基于规则的方法.例如，文献[1]通过设置降噪规则过滤告警信息，根据安全研判账号属性自动分发告警，关联告警信息与安全设备，并进行综合分析得出告警的研判结果.该方法难以覆盖复杂场景和未知模式.

2）基于传统机器学习的方法.例如，文献[2]通过特征提取、特征选择、告警数据聚合、相似度分析及半监督学习方法协同训练，有效研判高危 DDoS 攻击告警.该方法需要依赖高质量标注数据，标注成本高昂，模型更新慢.

3）基于大语言模型(large language model，LLM)的方法.例如，文献[3]通过采集组件获取告警信息，利用安全大模型零样本学习生成基于思维链的告警信息处置决策树，并据此对告警事件进行响应处置，实现高效的安全告警研判与处理.该方法存在模型幻觉与微调成本高的缺陷.

不同方法的优缺点如表 1 所示，基于规则和 LLM 的方法可解释性好；基于传统机器学习和 LLM 的方法未知威胁发现能力强；基于规则和传统机器学习的方法随机性与成本更低.

随着 LLM 的发展，以大模型驱动的 Agentic AI 逐渐成为研究热点.2023 年，OpenAI 公司提出 LLM-powered Agent 框架，认为 Agent 由 LLM、工

收稿日期：2025-09-15
基金项目：国家自然科学基金项目(62303012)
引用格式：范敏，张林波，李展，等. 告警研判智能体系统研究[J]. 信息安全研究，2025，11(增刊 2)：39-43

表 1　3 种告警研判方法对比

方法	优缺点
基于规则	优点：可解释性好、确定性强、成本低 缺点：无法应对未知威胁、规则冲突与膨胀
基于传统机器学习	优点：可关联多维数据发现复杂模式 缺点：可解释性差、数据标注成本高
基于 LLM	优点：可解释性好、未知威胁发现能力强 缺点：随机性高（幻觉）、成本高（基于高质量数据微调/预训练模型）

具、记忆以及推理规划构成.2024 年，谷歌提出智能体通用架构和组件，认为 Agent 由 LLM、工具以及编排组件构成.Agentic AI 有效解决了 Generative AI 领域知识幻觉性高、任务鲁棒性差、自主性弱等不足，逐渐成为各行业应用落地的关键技术.因此，本文基于 Agent 框架，结合 Agentic AI 技术优势，提出一套基于单智能体的告警研判系统 RIGTE-Agent-CV.该系统在开源基座模型上，结合安全专家的知识经验与工具，实现了兼具低成本、可解释性、高准确率与确定性的自动化告警研判.

2　系统设计

2.1　整体框架

系统整体框架如图 1 中所示，主要包括安全专家知识库检索、RIGTE 提示词工程、ReACT 框架智能体及多数投票 4 个模块.其中，ReACT 框架通过交替生成推理轨迹与任务特定动作，将 LLM 的推理能力与行动能力结合起来，增强模型在复杂任务中的表现.系统整体流程为：

1）接入安全设备上报的告警日志，提取告警名称（如“TCP_木马后门_Gh0stCringe_连接”）.

2）将告警名称输入安全专家知识库检索模块，检索出针对该告警的研判指令及条件推理知识 K.

3）将 K 输入 RIGTE 提示词工程模块得到 P，并输入智能体模块.

4）P 经过智能体的 ReACT 操作，得到一个响应输出.

5）基于响应输出进行多数投票得到最终结果 Y.

LLM 具有上下文学习、指令遵循与推理规划 3 大关键能力，而模型的能力决定了智能体的性能.本文系统模型需要依据安全专家的经验进行工具调用，这对模型的 3 大关键能力要求很高.因此，本文系统结合本地化资源与开源 LLM 能力测评榜单，选择 Qwen2.5-72B-Instruct-AWQ 作为基座模型.

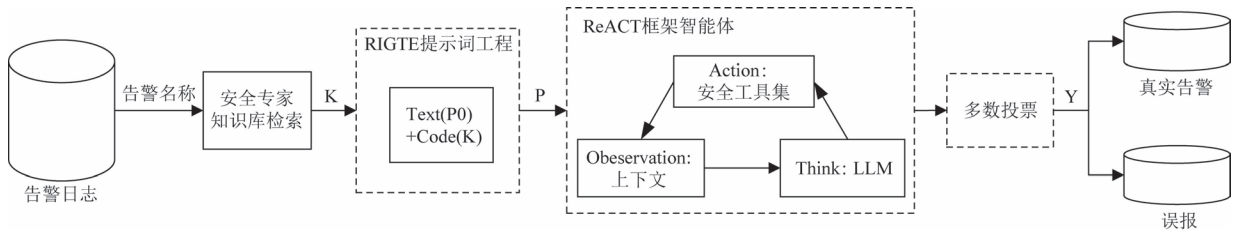


图 1　系统框架

2.2　知识库与工具集

基于不需微调 LLM 的低成本思路，通过引入安全专家的告警研判知识，解决了开源模型领域知识不够充分和专业，存在幻觉的问题.设备告警日志中的告警名称与告警研判知识库是多对一的映射关系，即多种不同的告警类型可映射到同一个研判知识库.本文构建了 20 个研判知识库，包括：

1）Web 漏洞类.涵盖命令执行、XSS、SQLi、PHP 反序列化、Log4j、Shiro 反序列化、XXE、Webshell 连接/上传.

2）僵木蠕.涵盖蔓灵花、银狐、挖矿、明文代理、DNS 域名请求、Cobalstrike.

3）横向二进制类.涵盖内外网扫描器、可疑行为、远程调用、横向工具、二进制漏洞.

每个知识库均包含知识库名称、告警匹配规则与研判任务 3 个部分.以横向二进制类的内外网扫描器为示例，其知识库如表 2 所示：

表 2　内外网扫描器知识库

项	值
知识库名称	横向二进制-内外网扫描器
匹配规则	^.*?''.*?（nmap|Fscan|Gonmap|Yasso)(\b|_).*?''.*?''.*?''.*?$

续表 2

项	值
研判任务	1）使用安全告警日志查询工具查询告警事件 ID 的全部信息，但不要给出任何判断和输出 2）将其状态标记为“可疑”，使用威胁情报查询工具查询攻击者的 IP，检查攻击者 IP 是否为白名单中的地址，根据事件名称解释使用了何种扫描器，具体扫描协议是什么 3）尝试根据事件中描述的行为解析对应的数据包内容.如果无法解析数据包则解析失败，给出判断；如果可以解析，分析数据包的威胁程度及可能造成的威胁.当告警事件源 IP 来自于内网时，判断源 IP 失陷的可能性 4）配合威胁情报查询结果解释该告警出现的原因以及风险程度，并给出“暂时封禁源 IP”“关闭暴露的高危端口”等建议

由于开源模型的内部知识已在训练阶段静态固化，无法获取环境的实时动态信息，因此引入安全工具集.本文一共构建了 8 种安全工具集，包括安全告警日志查询、威胁情报查询、沙箱检测、Web 日志检测、资产数据查询、PCAP 文件检测、僵木蠕解码工具及域名白名单.

2.3 RIGTE 提示词工程

本文首次提出结合思维链的 RIGTE 提示词框架，包括 Role（角色）、Input（输入）、Goal（目标）、Task（任务）、Expectation（期望）5 个模块.将安全专家知识放入其中的 Task 模块，形成初始提示词 P0，如下所示：

＃Role＃ 指定 LLM 应扮演的角色

＃Input＃ 带告警日志 ID 的用户输入

＃Goal＃ 说明 LLM 最终要完成的目标

＃Task＃ 插入表 2 中的研判任务

＃Expectation＃ 定义期望的输出形式

P0 的关键作用是让 LLM 严格遵循 Task 中的指令并按条件进行推理.Mishra 等人[4]发现使用伪代码提示可提高 LLM 的指令遵循能力，Puerto 等人[5]发现使用代码提示可激发 LLM 的条件推理能力.因此，本文基于上述工作，结合图模互补的思路，将 P0 中 Task 中的自然语言转化为基于图的代码提示词 P，其余部分不变，形式化定义如下：

$$\exists C, f: \mathrm{N} \rightarrow C, \sigma(LLM(f(\mathrm{P}))) \geqslant \sigma(LLM(\mathrm{P})), \tag{1}$$

$$\sigma = \frac{TP+TN}{TP+FP+TN+FN}, \tag{2}$$

其中，C 表示代码集合，N 表示自然语言，P 表示提示词.σ 是采用准确率表示的评估函数.其中，TP 表示真正例，即实际为正类且被模型正确预测为正类的样本数量；TN 表示真负例，即实际为负类且被模型正确预测为负类的样本数量；FP 表示假正例，即实际为负类但被模型错误预测为正类的样本数量；FN 表示假负例，即实际为正类但被模型错误预测为负类的样本数量.

2.4 多数投票

LLM 推理路径具有随机性，即在同一个提示词和上下文中仍有一定概率推理出不同的结论.Wang 等人[6]发现通过自一致性方法可提升 LLM 在推理任务中的表现.Lin 等人[7]发现通过生成多个不同的推理路径，选择其中相同的答案作为最终结果，可提升 LLM 的推理性能.Chen 等人[8]从理论上证明了增加并行计算等效于扩大模型参数来增强模型能力，即将并行推理扩展 n 倍可将模型损失降低 $\log(n)$ 倍，形式化定义如下：

$$L \propto \frac{1}{s \cdot Diversity}, \tag{3}$$

$$Diversity = k \cdot \log(n) + 1, \tag{4}$$

其中，L 表示交叉熵损失，s 表示模型参数量，n 表示并行推理的数量，k 表示并行收益系数.

基于上述工作，本文利用 LLM 进行多数投票，即从多个不同的输出结果中选择出现次数最多的一个，通过该机制减少推理随机性，提高告警研判的准确率.具体如算法 1 所示：

算法 1. 多数投票算法.

输入：提示词 P、最大生成次数 G；

输出：投票结果 R.

① 初始化一个为空列表，创建一个进程池，指定 G 个进程；

② 并行执行 P，等待所有进程完成；

③ 将每个进程的结果追加到空列表；

④ 返回列表中的结果 R.

3 实验分析

3.1 实验环境

数据集分为公共数据集和自有数据集 2 部分，所有实验都在一台高性能服务器上完成.配置为 4 张 NVIDIA GeForce RTX 3090 显卡，总显存为 96 GB，总内存为 128 GB，开源模型选择 Qwen2.5-

72B-Instruct-AWQ.另外，在自有数据集中，本文定义的“准确”，不仅研判结果要准确，而且研判过程也要准确.

3.2 公共数据集对比实验

公共数据集采用ConditionalQA[9]和ShARC[10]2个.ConditionalQA是一个复杂阅读理解的问答数据集，包括是非问题、多答案问题及不可回答问题等，本文提取是非问题（答案为“yes”或“no”）进行实验，共1 350条；ShARC是一个多轮对话式的问答数据集，本文采用文献[10]的方法提取回答只有“yes”或“no”的问题，共790条.

在公共数据集中采用3种方法实验，包括基于自然语言的提示（NL-Prompt），基于代码的提示（Code-Prompt）和加入多数投票机制的代码提示（Code-Prompt-V），采用统计学中用于评估二分类模型性能的指标$F1$作为研判准确率指标，最大生成次数为5.实验结果如图2所示，从图中可看出：Code-Prompt的条件推理能力优于NL-Prompt，Code-Prompt-V则带来进一步提升.

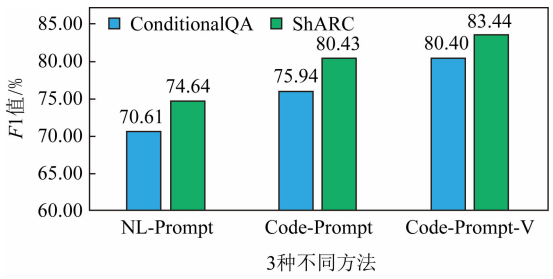


图2 公共数据集对比实验

3.3 自有数据集对比实验

自有数据集基于现网真实流量搜集，包含恶意和良性共501个样本，每个样本产生一条告警日志，其中Web类告警178条，僵木蠕类告警264条，横向二进制类告警59条.

在自有数据集中采用4种方法实验，包括不带知识库和工具集的开源LLM（Naive-LLM）、基于RIGTE提示词工程的智能体系统（RIGTE-Agent）、代码提示智能体系统（RIGTE-Agent-C）、加入多数投票机制的代码提示智能体系统（RIGTE-Agent-CV）.在RIGTE-Agent-CV中，首先确定多数投票的最大生成次数，实验结果如图3所示.从图中可看出，随着最大生成次数的增加，研判准确率先增加后平缓.本文结合性能和本地资源约束，选择最大生成次数为7次.

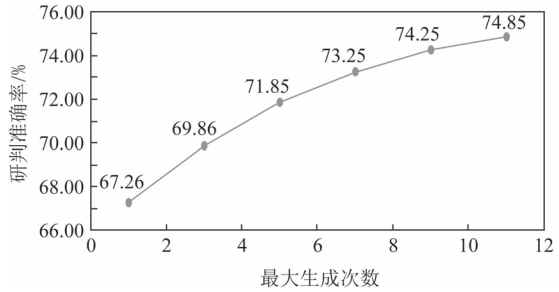


图3 确定最大生成次数

针对不同类告警的研判准确率如图4所示，从图中可以看出：

1）专家知识、安全工具、代码提示及多数投票机制均能提高研判准确率.

2）RIGTE-Agent-CV相比Naive-LLM在Web类告警中提升了38%，在僵木蠕类告警中提升了48%，在横向二进制类告警中提升了24%.

3）4种方法对Web类告警的研判准确率最高，对横向二进制类告警的研判准确率最低，说明模型对不具备语法和语义信息的二进制类载荷分析能力较弱，需要对应的横向二进制解码工具.

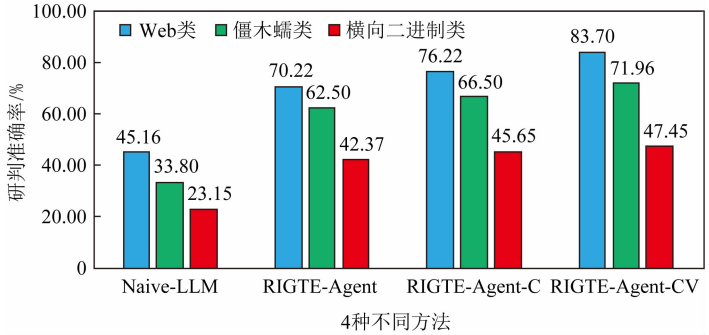


图4 自有数据集对比实验

4 结　　语

本文基于 ReACT 框架的智能体技术，融合知识驱动与工具反馈机制，构建了一种告警研判智能体系统 RIGTE-Agent-CV. 该系统利用开源模型的上下文学习、指令遵循及推理能力，同时结合多数投票机制，显著提升了告警研判的准确率. 在公共数据集上的对比实验发现，代码提示能有效提升模型的条件推理能力，多数投票机制能减少模型输出的随机性. 在自有数据集上的对比实验发现，本文系统在不同类型的告警中都具有更好的研判准确率，且具备可解释性与未知威胁发现能力. 但本文系统仍然存在一些问题：如何保持性能的同时降低推理成本、如何进一步提高研判准确率、如何自动化评估等，这些均属于未来重点研究方向.

参 考 文 献

[1] 中国交通信息科技集团有限公司. 一种安全运营告警研判的方法及装置：中国，202311620555.1 [P]. 2024-04-16

[2] 卓望数码技术（深圳）有限公司. 一种基于半监督学习的 DDoS 攻击告警研判方法以及装置：中国，202311148079.8 [P]. 2023-10-13

[3] 同方知网数字出版技术股份有限公司. 基于安全大模型的告警研判处置方法、装置及计算机设备：中国，202411659863.X [P]. 2025-03-07

[4] Mishra M, Kumar P, Bhat R, et al. Prompting with pseudo-code instructions [EB/OL]. 2023 [2025-07-13]. https://arxiv.org/pdf/2305.11790

[5] Puerto H, Tutek M, Aditya S, et al. Code prompting elicits conditional reasoning abilities in text＋code LLMs [EB/OL]. 2024 [2025-07-13]. https://arxiv.org/pdf/2401.10065

[6] Wang X, Wei J, Schuurmans D, et al. Self-consistency improves chain of thought reasoning in language models [EB/OL]. 2022 [2025-07-13]. http://arxiv.org/pdf/2203.11171

[7] Lin L, Fu J, Liu P, et al. Just ask one more time! self-agreement improves reasoning of language models in (almost) all scenarios [EB/OL]. 2024 [2025-07-13]. http://doi.org/10.18653/v1/2024.findings-acl.230

[8] Chen M, Hui B, Cui Z, et al. Parallel scaling law for language models [EB/OL]. 2025 [2025-07-13]. https://arxiv.org/pdf/2505.10475

[9] Sun H, Cohen W W, Salakhutdinov R. ConditionalQA: A complex reading comprehension dataset with conditional answers [EB/OL]. 2021 [2025-07-13]. https://arxiv.org/pdf/2110.06884

[10] Saeidi M, Bartolo M, Lewis P, et al. ShARC 数据集[EB/OL]. [2018-08-28]. https://sharc-data.github.io

范　敏

工程师. 主要研究方向为机器学习与网络安全.

fan_min2@venusgroup.com.cn

张林波

工程师. 主要研究方向为网络安全.

zhanglb@cert.org.cn

李　展

教授. 主要研究方向为机器学习与机器人.

zhan.li@swjtu.edu.cn

燕敬博

高级工程师. 主要研究方向为网络安全监测分析.

yanjb@cert.org.cn

陈　亘

工程师. 主要研究方向为僵木蠕和 APT.

chengen@venusgroup.com.cn

刘丽丽

工程师. 主要研究方向为网络安全.

lll_1qaz@163.com

董逸天

主要研究方向为网络流量工程与无线网络优化.

dongyitian@hotmail.com